

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1407

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across

different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

1. How would you identify and prioritize vulnerabilities after discovering multiple open ports during a port scan?

After discovering multiple open ports, I would first identify the services and applications running on each port. For example, port 22 may indicate SSH, port 21 FTP, port 80 HTTP, and port 3306 MySQL.

Approach:

1. Identify the service running on each open port.
2. Determine the service version using authorized service/version detection.
3. Check whether the identified version has any known vulnerabilities.
4. Assess whether the service is necessary and properly configured.
5. Prioritize vulnerabilities based on:
 - Severity of the vulnerability.
 - Whether the service is exposed to the Internet.
 - Sensitivity of the data handled by the service.
 - Possibility of unauthorized access.
 - Availability of patches or security updates.
6. Critical and high-risk vulnerabilities should be fixed first.
7. Document the findings and recommend suitable security controls.

2. A SYN scan and a TCP Connect scan produce different results on the same target. What factors could cause this difference, and how would you verify the findings?

A SYN scan and a TCP Connect scan use different methods to determine whether a TCP port is open.

A SYN scan sends a SYN packet and analyzes the response without completing the full TCP connection. A TCP Connect scan completes the normal TCP three-way handshake.

Possible reasons for different results:

- Firewall or IDS/IPS rules may treat the two scan types differently.
- Network security devices may drop or modify packets.
- The target may use connection filtering or rate limiting.
- Temporary network problems may cause packets to be lost.
- The service may start or stop between scans.
- Different scan timing or network conditions may affect the results.
- Some systems respond differently to incomplete and complete TCP connections.

Verification:

I would repeat both scans under the same network conditions and compare the results. I would also use service/version detection to identify the application behind the port.

If necessary, I would check firewall or IDS logs and perform the scan from another authorized location to determine whether filtering is affecting the results.

Therefore, a difference between the scans should be verified rather than immediately treated as a confirmed vulnerability.

3. During a port scan, most ports appear as "filtered." What security mechanisms might be responsible, and what additional techniques would you use to gather more information?

A port is shown as filtered when the scanner cannot determine whether the port is open because network traffic is being blocked or dropped.

Possible security mechanisms:

- Firewall rules may block incoming packets.
- Network Access Control Lists (ACLs) may restrict traffic.
- Intrusion Detection/Prevention Systems (IDS/IPS) may detect and block scans.
- Routers may use packet filtering.
- Host-based firewalls may block unwanted connections.

- Rate limiting may temporarily block repeated scan requests.

Additional techniques:

1. Perform scans using different authorized TCP scan methods.
2. Perform UDP scanning to check UDP services.
3. Use service/version detection on ports that respond.
4. Check firewall and IDS/IPS logs if access is available.
5. Perform the assessment from an authorized internal network position.
6. Compare results at different times to identify temporary filtering.
7. Use network administrators' configuration information to confirm filtering rules.

The goal is to determine whether the port is actually closed, open but protected, or simply being blocked by a security device.

4. Compare TCP, UDP, and stealth (SYN) port scanning techniques. In which scenarios would each be the most effective, and what are their advantages and limitations?

Scan Type	Description	Advantages	Limitations
TCP Connect Scan	Completes the TCP three-way handshake	Reliable and simple; works without raw-packet privileges	Creates a full connection and may be logged
UDP Scan	Sends UDP packets to identify UDP services	Useful for finding DNS, DHCP and other UDP services	Slower and results can be difficult to interpret
SYN/Stealth Scan	Sends SYN packets without completing the connection	Faster and generally produces less application-level connection activity	Can still be detected by firewalls and IDS/IPS

TCP Connect Scan

It is useful when reliable TCP port information is required or when the scanner does not have the privileges needed for a SYN scan.

Advantage: High reliability.

Limitation: The complete connection can be recorded by the target system.

UDP Scan

It is useful when checking for services that communicate using UDP, such as DNS and DHCP.

Advantage: Finds services that TCP scanning cannot detect.

Limitation: UDP scanning is usually slower and may produce ambiguous results because many UDP services do not respond to unexpected packets.

SYN/Stealth Scan

It is useful for authorized security assessments when checking TCP ports efficiently without completing the normal connection.

Advantage: Fast and efficient for TCP port discovery.

Limitation: It is not invisible; firewalls and intrusion detection systems can still detect scan activity.

5. Suppose you are conducting an authorized security assessment and discover critical services such as SSH, FTP, and database ports exposed to the Internet. How would you assess the risks and recommend mitigation strategies?

Internet-exposed critical services can significantly increase the attack surface of an organization. I would first identify the service versions, configurations, authentication mechanisms, and whether access is actually required from the Internet.

Risk assessment

SSH:

- Risk of password-guessing or brute-force attacks.
- Weak authentication can lead to unauthorized access.
- Outdated SSH software may contain vulnerabilities.

FTP:

- Traditional FTP may transmit information without adequate encryption.
- Weak credentials can be compromised.
- Anonymous access, if enabled unnecessarily, can create additional risk.

Database ports:

- Direct Internet exposure can allow unauthorized connection attempts.
- Weak database credentials may lead to data compromise.
- Vulnerable or outdated database software may be exploited.
- Sensitive organizational data could be exposed.

Recommended mitigation

1. Close unnecessary Internet-facing ports.
2. Restrict access using a firewall and allowlisting.
3. Keep operating systems and services patched and updated.

4. Use strong passwords and multi-factor authentication where supported.
5. For SSH, prefer key-based authentication and disable unnecessary login methods.
6. Replace insecure FTP with a secure alternative such as SFTP where appropriate.
7. Do not expose database services directly to the Internet unless there is a strong business requirement.
8. Place databases behind a firewall or private network.
9. Apply least-privilege access controls.
10. Continuously monitor logs and perform regular vulnerability assessments.

Conclusion

The highest priority should be given to services that are Internet-facing, outdated, unnecessary, or handling sensitive information. Reducing public exposure, applying patches, strengthening authentication, and monitoring access can significantly reduce the risk.